TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Langflow patches critical unauthenticated auth-bypass and code-execution flaws

From **Cybersecurity Briefing** · 2026-10-28 to 2026-11-02 (US/Global/Industry focus on the last 24 hours plus weekend; local sections cover five days) · Briefing generated 2026-11-02

REPORT ID	VERSION	HANDLING
CTI-20261102-04	1.0 · 2026-11-02 12:40 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
	2026-10-28	2026-11-02
CVES	**ANALYST**	
CVE-2026-93680 (CVSS 9.8), CVE-2026-110186 (CVSS 9.8), CVE-2026-110193 (CVSS 8.8), CVE-2026-110192 (CVSS 6.5)	Nick Sturgeon	

VULNERABILITY | CRITICAL | PATCH AVAILABLE; NO CONFIRMED IN-THE-WILD EXPLOITATION REPORTED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

IBM, which now issues CVEs for Langflow, published a bulletin on 2026-10-28 and revised it on 2026-10-29. It covers Langflow OSS 1.0.0 through 1.12.8 [S2] [S11]. Two flaws need no account and score CVSS 9.8: CVE-2026-93680, an improper authentication bypass, and CVE-2026-110186, code injection leading to arbitrary code execution [S2] [S3] [S4]. Two more need a low-privileged account: CVE-2026-110193 (8.8), where the Agentic Assistant can be used to run OS commands on the server, and CVE-2026-110192 (6.5), which exposes insufficiently protected credentials [S2] [S5] [S6]. The bulletin also lists three lower-severity flaws in the bundled Hono framework [S2]. Version 1.13.0, released 2026-10-22, is the only fix, and IBM offers no workaround [S1] [S2].

We found no report of in-the-wild exploitation of these four CVEs as of 2026-11-02, and none is in the CISA KEV catalog (version 2026.10.30, the newest available when checked) [S1] [S10] [S17]. Risk is still high, for three reasons. CISA's SSVC enrichment marks the two 9.8 flaws as automatable with total technical impact [S3] [S4]. A public Metasploit auxiliary module for CVE-2026-93680 opens an MCP session without credentials and lists the server's tools, though it does not run code [S1] [S7] [S8]. Six other Langflow flaws

are already in KEV, and honeypots logged hundreds to more than a thousand attempts against other Langflow flaws in September and October 2026 [S17] [S21] [S22].

Key details remain unsettled. IBM's records are one line each and name no endpoints [S11]. Its bulletin summary links unauthenticated code execution to MCP tool enumeration and refers to an incomplete fix for an auto-login control, but no individual CVE entry describes the mechanism [S1] [S2]. The affected ranges also differ: IBM says 1.0.0 through 1.12.8, while the Metasploit author says 1.5.0 through 1.11.4 [S1] [S2] [S9]. Sources also disagree on whether turning auto-login off closes the unauthenticated path. Ostorlab says it does, a tracking page from HOL says the risk remains, and IBM is silent [S1] [S10] [S12]. Do not treat LANGFLOW_AUTO_LOGIN=false as a fix.

Upgrade every instance to 1.13.0 and remove Langflow from direct internet exposure. Plan the upgrade carefully: 1.13.0 turns auto-login off by default, so auto-login installs must prepare the existing account for password sign-in first, and operators should not delete or reinstall Langflow if locked out, because flows can be lost [S1] [S13] [S14] [S15]. Any instance that was reachable from untrusted networks on an affected version should be reviewed for compromise, and its stored model, tool and cloud credentials rotated if untrusted parties could have had access [S10] [S11].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE
Exploitation attempts against CVE-2026-93680 or CVE-2026-110186 will very likely be reported by honeypot or threat-intelligence operators by the end of November 2026. Attackers already probe the auto-login endpoint on Langflow honeypots, public tooling exists for the MCP access step, and attempts against CVE-2026-33017 were documented within about twenty hours of its advisory. [S1] [S8] [S21] [S24]

LIKELY · MODERATE CONFIDENCE
A public proof of concept or module that achieves code execution through these flaws, not just MCP enumeration, is likely to appear by the end of November 2026. Ostorlab has described a path from auto-login to server-side code execution, and the same Metasploit contributor has already written five Langflow exploit modules for other CVEs. [S9] [S10]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that CISA adds at least one of these four CVEs to KEV by the end of 2026. Six Langflow flaws are listed, five of them added since March 2026, but KEV listing requires evidence of exploitation and none has been reported for these CVEs. CISA's current SSVC entries for the two critical flaws record exploitation as none. [S3] [S4] [S17]

LIKELY · MODERATE CONFIDENCE
A meaningful share of internet-exposed Langflow servers will likely still run affected versions 30 days after this report. The upgrade can lock out auto-login installs, IBM offers no interim workaround, and many deployments are likely unmanaged or outside normal patching. No current exposure count exists to measure this directly. [S2] [S14] [S24] [S25]

> VERY LIKELY · MODERATE CONFIDENCE
> If these flaws are exploited, attackers will very likely prioritize credential theft, including model API keys, cloud credentials and Langflow's own secret key, because that behavior dominated recently observed activity against other Langflow flaws. [S21] [S22]

INDICATORS OF COMPROMISE

No source publishes attacker infrastructure or malware tied to these four CVEs, so the first group of entries is behavioral and describes requests, tooling and configuration. Entries whose context begins 'Related activity' come from 2026 reporting on other Langflow CVEs; they are for retrospective hunting, may be shared infrastructure, and do not indicate exploitation of the flaws in this report.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`GET /api/v1/auto_login`	Per Ostorlab, returns a superuser session (200) when auto-login is on and 403 when it is off. Requests from unexpected sources are a reported log-review indicator. Previdian honeypots also saw this path probed during attacks on another Langflow flaw.	REPORTED		[S10] [S21]
http-request	`/api/v1/mcp/sse`	MCP SSE endpoint that HOL says the Metasploit module reaches without credentials. HOL says a 200 with an event stream means the endpoint is open to anyone and a 401 or 403 means credentials are required.	REPORTED		[S11] [S12]
http-request	`/api/v1/agentic/mcp`	MCP endpoint that Ostorlab says exposes flow-authoring and execution tools and is reachable with a superuser session. This differs from the path HOL reports, so hunt on both.	REPORTED		[S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST to the MCP message endpoint with a session identifier query parameter, JSON-RPC methods initialize, notifications/initialized and tools/list, answered with HTTP 202`	Request sequence used by the public Metasploit module after it opens the SSE connection. The module's own notes say it leaves indicators in logs.	REPORTED	2026-09-22	[S7] [S8]
other	`MCP initialize request declaring protocol version 2025-06-18 with Accept: application/json, text/event-stream`	Attributes of the Metasploit module's request as described in its pull request. The values are common to legitimate MCP clients, so they support other evidence but are not enough on their own.	REPORTED	2026-09-22	[S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`langflow_auth_bypass_cve_2026_93680.rb`	Public Metasploit auxiliary module, path auxiliary/gather/langflow_auth_bypass_cve_2026_93680. Useful as a tooling reference; it would not normally appear on a victim host.	REPORTED	2026-09-22	[S1] [S7] [S9]
port	`7860/tcp`	Default Langflow port and the Metasploit module's default. A 0.0.0.0:7860 binding on a publicly reachable host is an urgent exposure finding.	REPORTED		[S7] [S8] [S11]
other	`LANGFLOW_AUTO_LOGIN unset or true on versions 1.12.8 and earlier`	Configuration exposure indicator. AUTO_LOGIN defaults to true in 1.12.8 and the code warns it is for development only. Whether disabling it fully protects affected versions is disputed.	REPORTED		[S1] [S10] [S16]
other	`LANGFLOW_SKIP_AUTH_AUTO_LOGIN=true`	Configuration exposure indicator. With auto-login on, this setting lets unauthenticated API requests run as the superuser. Its presence on any shared server warrants review.	REPORTED		[S14]
http-request	`/api/v1/mcp/project/<PROJECT_ID>/streamable`	Documented project MCP endpoint using streamable HTTP. Not named in any exploit report. Included because tool enumeration could plausibly target it as well as the SSE path, and project servers can be set to no authentication.	DERIVED		[S26]
http-request	`PATCH /api/v1/users/{id} from an unexpected source`	HOL documents this as the password-setting route used in recovery. An attacker holding a superuser session could plausibly use the same route to take over an account, so calls outside a planned upgrade deserve review.	DERIVED		[S11] [S14]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /api/v1/users/ from an unexpected source`	Documented self-registration route. CVE-2026-110193 and CVE-2026-110192 need only a low-privileged account, so unexpected registrations could precede their exploitation where signup is enabled.	DERIVED		[S5] [S6] [S14]
http-request	`GET /api/v1/version from an external source`	HOL documents this as a version check, and Previdian saw attackers check the version first. External requests preceding auto-login or MCP requests may indicate reconnaissance.	DERIVED		[S11] [S21]
command	`Shell or download utility (sh, bash, curl, wget) spawned by the Langflow Python process`	Code and OS command execution through CVE-2026-110186 or CVE-2026-110193 should appear as unusual child processes of the server process. Custom components can make this legitimate on some servers, so baseline first.	DERIVED		[S4] [S5] [S10]
other	`New or modified custom components in flows; accounts or API keys created during the exposure window`	Artifacts Ostorlab advises reviewing on previously exposed instances.	REPORTED		[S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`192[.]255[.]229[.]92`	Related activity: source of a significant share of honeypot attempts against CVE-2026-105740. GreyNoise and Previdian also link it to brute-force attacks and to exploitation of other Flowise and Langflow flaws.	REPORTED		[S21]
ipv4	`146[.]70[.]211[.]112`	Related activity: destination, on port 18764, for environment variables and configuration data exfiltrated in the CVE-2026-105740 activity.	REPORTED		[S21]
ipv4	`185[.]177[.]72[.]0/24`	Related activity: European scanning subnet of at least 15 hosts probing CVE-2026-0768 with marker-based checks. F5 suggests considering a temporary block as a supplementary measure.	REPORTED		[S22]
ipv4	`185[.]177[.]72[.]38`	Related activity: example host from the CVE-2026-0768 probing sequence.	REPORTED		[S22]
ipv4	`35[.]200[.]23[.]10`	Related activity: Google Cloud source, 86 CVE-2026-0768 events, in a cluster harvesting environment data. May be shared infrastructure.	REPORTED		[S22]
ipv4	`35[.]229[.]191[.]244`	Related activity: Google Cloud source, 71 CVE-2026-0768 events, in the same cluster. May be shared infrastructure.	REPORTED		[S22]
ipv4	`35[.]233[.]194[.]235`	Related activity: Google Cloud source, 29 CVE-2026-0768 events, sending near-identical payloads while rotating user agents. May be shared infrastructure.	REPORTED		[S22]
ipv4	`142[.]93[.]57[.]244`	Related activity: DigitalOcean range source that ran a default-argument execution check using id against CVE-2026-0768.	REPORTED		[S22]
ipv4	`61[.]163[.]138[.]201`	Related activity: China-hosted source, single CVE-2026-0768 event.	REPORTED		[S22]
ipv4	`125[.]46[.]149[.]49`	Related activity: China-hosted source, single CVE-2026-0768 event.	REPORTED		[S22]
http-request	`POST /api/v1/validate/code`	Related activity: endpoint used in all 405 CVE-2026-0768 events F5 logged in September 2026; the JSON code field carries the Python payload. Also the CVE-2025-3248 endpoint.	REPORTED	2026-09-11	[S11] [S22]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /api/v2/mcp/servers/{server_name}`	Related activity: adds a malicious MCP server with a crafted command in CVE-2026-105740 attacks. The configuration persists in project settings and does not show in normal flow review.	REPORTED	2026-09-19	[S21]
http-request	`GET /api/v2/mcp/servers?action_count=true`	Related activity: triggers the stored command in CVE-2026-105740 attacks.	REPORTED	2026-09-19	[S21]
user-agent	`curl/8.7.1`	Related activity: used by all requests in the 185.177.72.0/24 probing family. Common legitimate value, so use only with other evidence.	REPORTED		[S22]
other	`abp_cvq3zzjptdwg`	Related activity: example unique marker string returned in an exception to confirm code execution in CVE-2026-0768 probing. Markers vary per request; the abp_ prefix is the more useful pattern.	REPORTED		[S22]
other	`abp_1x9k76sfoh04`	Related activity: second example marker string from the same probing family.	REPORTED		[S22]
filepath	`/proc/self/environ`	Related activity: read as a fallback in environment-harvesting payloads against CVE-2026-0768.	REPORTED		[S22]
filepath	`/etc/passwd`	Related activity: read attempts through Docker commands during CVE-2026-105740 attacks.	REPORTED		[S21]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Requests spoofing X-Forwarded-For, X-Client-IP, True-Client-IP or X-Azure-ClientIP as 127.0.0.1`	Related activity: localhost forwarding headers spoofed in CVE-2026-0768 traffic, alongside forged AI-crawler user agents.	REPORTED		[S22]
other	`New cron files, new SSH authorized keys, unfamiliar Python files in Langflow package directories, unexplained outbound connections`	Related activity: host-level indicators the Cloud Security Alliance lists for CVE-2026-5027. Reasonable general checks for a compromised Langflow host.	REPORTED		[S24]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The exact exploit chain is not officially documented, because IBM names no endpoints. Two public descriptions exist. Ostorlab describes an anonymous request to the auto-login route returning a superuser session, which is then used on an MCP endpoint where custom component code runs on the server [S10]. The Metasploit module takes a more limited path: it connects to the MCP SSE endpoint without credentials, initializes a session and lists tools, without calling any auto-login route and without executing code; it was tested on 1.8.4 with auto-login enabled [S1] [S7] [S8]. Separately, a low-privileged user can abuse the Agentic Assistant to run OS commands (CVE-2026-110193) or obtain insufficiently protected credentials (CVE-2026-110192) [S5] [S6]. ATT&CK mappings below are analyst judgments based on this reporting, and post-exploitation entries are drawn from attacks on other Langflow flaws.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Version checks and auto-login probes, as seen against Langflow honeypots in a related campaign. Not yet reported for these four CVEs. [S21]	External requests to version, auto-login and MCP paths from one source in a short window.
Initial Access	T1190 Exploit Public-Facing Application	Unauthenticated network exploitation of CVE-2026-93680 or CVE-2026-110186, both rated network-reachable with low complexity and no user interaction. [S3] [S4] [S10]	External access to auto-login and MCP paths, especially successful responses without prior sign-in.
Defense Evasion	T1078 Valid Accounts	Using the superuser session issued by the auto-login route, or a low-privileged account, to act as a legitimate user. [S5] [S10]	Superuser activity from unfamiliar sources; sessions without a matching password sign-in.
Discovery	T1518 Software Discovery	Listing MCP server information and available tools through tools/list. This is the closest ATT&CK fit for MCP tool enumeration, not an exact match. [S7] [S8]	JSON-RPC tools/list requests from unknown clients; SSE sessions from external addresses.
Execution	T1059.006 Command and Scripting Interpreter: Python	Server-side execution of custom component code, reached through the MCP endpoint according to Ostorlab. [S4] [S10]	New custom components; unusual child processes or outbound connections from the Langflow process.

Tactic	Technique	Procedure observed	Detection opportunity
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	A low-privileged user has the Agentic Assistant generate or submit component code that runs OS commands (CVE-2026-110193). The bulletin lists Windows, Linux and Mac OS, so the shell depends on the host. [S2] [S5]	Shell processes spawned by Langflow; Agentic Assistant use by unexpected accounts.
Credential Access	T1552 Unsecured Credentials	An authenticated user obtains insufficiently protected credentials (CVE-2026-110192). Ostorlab describes these as operator-injected API keys; IBM's CVE text does not say so directly. [S2] [S6] [S10]	Unusual reads of global variables or settings by low-privileged accounts; later use of stored keys from new locations.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Related activity: harvesting environment data through env and /proc/self/environ, seen against CVE-2026-0768. F5 maps this activity to T1552.001. [S22]	Reads of /proc/self/environ by the server process; env executed by a child shell.
Persistence	T1136 Create Account	Inferred from Ostorlab's advice to review accounts and API keys created during the exposure window. Not reported as observed. [S10]	New users or API keys that do not match change records.
Exfiltration	T1048 Exfiltration Over Alternative Protocol	Related activity: environment and configuration data sent to a remote host on a high port in the CVE-2026-105740 attacks. [S21]	Outbound connections from Langflow hosts to unknown addresses on non-standard ports.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

External access to Langflow auto-login and MCP endpoints `SIGMA`

```
title: External Access to Langflow Auto-Login or MCP Endpoints
status: experimental
logsource:
  category: webserver
detection:
  selection:
    cs-uri-stem|contains:
      - '/api/v1/auto_login'
      - '/api/v1/mcp/sse'
      - '/api/v1/agentic/mcp'
  filter_internal:
    c-ip|cidr:
      - '10.0.0.0/8'
      - '172.16.0.0/12'
      - '192.168.0.0/16'
      - '127.0.0.0/8'
  condition: selection and not filter_internal
falsepositives:
  - Authorized MCP clients and vulnerability scanners
level: high
```

Requires logs from a reverse proxy or web server in front of Langflow. Add known client addresses to the filter. A 200 response to auto_login or an event stream from the SSE path is the higher-priority result.

Langflow probing sequence from a single source `SPLUNK SPL`

```
index=web (uri_path="/api/v1/version" OR uri_path="/api/v1/auto_login" OR uri_path="/api/v1/mcp/sse" OR
uri_path="/api/v1/agentic/mcp" OR uri_path="/api/v1/validate/code" OR uri_path="/api/v2/mcp/servers*")
| bin _time span=1h
| stats dc(uri_path) AS distinct_paths values(uri_path) AS paths values(status) AS statuses count BY
_time src_ip dest
| where distinct_paths >= 2
| sort - distinct_paths
```

Adjust the index and field names to your environment. Finds sources touching several Langflow paths in one hour, covering both this report's flaws and related campaigns.

Shell or download tool spawned by Langflow `KQL`

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessCommandLine has "langflow"
| where FileName in~ ("sh", "bash", "dash", "zsh", "curl", "wget", "nc", "ncat", "cmd.exe",
"powershell.exe", "whoami", "id", "env")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc
```

For Microsoft Defender for Endpoint. Components and MCP stdio servers can spawn processes legitimately, so baseline each server. Container workloads need runtime telemetry because host EDR may not attribute the process to Langflow.

Langflow auto-login request and MCP tool listing over cleartext HTTP `SURICATA`

```
alert http any any -> $HOME_NET 7860 (msg:"Possible Langflow auto_login request";
flow:established,to_server; http.uri; content:"/api/v1/auto_login"; startswith; classtype:attempted-
recon; sid:9200001; rev:1;)
alert http any any -> $HOME_NET 7860 (msg:"Possible Langflow MCP tools/list request";
flow:established,to_server; http.method; content:"POST"; http.request_body; content:"tools/list";
classtype:attempted-recon; sid:9200002; rev:1;)
```

Sees only unencrypted traffic on the default port; adjust the port or place the sensor after TLS termination. The second rule also fires on legitimate MCP clients, so limit it to untrusted source ranges. Replace the sample SIDs with values from your local range.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
IBM Langflow OSS	1.0.0 through 1.12.8 per IBM; Metasploit author lists 1.5.0 through 1.11.4	1.13.0	CVE-2026-93680	9.8	0.02181 (82nd percentile, 2026-11-02)	No	N/A
IBM Langflow OSS	1.0.0 through 1.12.8	1.13.0	CVE-2026-110186	9.8	0.00622 (50th percentile, 2026-11-02)	No	N/A
IBM Langflow OSS	1.0.0 through 1.12.8	1.13.0	CVE-2026-110193	8.8	0.00777 (56th percentile, 2026-11-02)	No	N/A
IBM Langflow OSS	1.0.0 through 1.12.8	1.13.0	CVE-2026-110192	6.5	0.00249 (16th percentile, 2026-11-02)	No	N/A

Immediate (0–24 hours)

- Find every Langflow instance, including developer machines, containers and cloud workloads. Check the running version with pip show langflow or inside the running container, and do not rely on a freshly pulled image. `IT OPS` [S10] [S11]

- Remove internet exposure now: close port 7860 or the published proxy path, or place an authenticating proxy in front of all Langflow paths. This reduces exposure but does not remove the flaws, and it does not address CVE-2026-110193 for existing account holders. `IT OPS` [S1] [S10] [S11]
- Back up the database, secret key and uploaded files, then prepare auto-login installs for password sign-in by setting a password on the existing account and setting LANGFLOW_SUPERUSER and LANGFLOW_SUPERUSER_PASSWORD. Keep the same superuser username and encryption key. `IT OPS` [S1] [S2] [S14]
- Upgrade to 1.13.0 using pip install --upgrade "langflow==1.13.0" or the pinned langflowai/langflow:1.13.0 Docker image, keeping persistent data. If sign-in fails, follow Langflow's recovery steps and do not delete or reinstall, because that can permanently remove flows. `IT OPS` [S1] [S2] [S11] [S15]
- Search available web and proxy logs for the auto-login, MCP and related paths in this report, starting from at least 2026-09-22 when the public module work began. Treat any previously exposed host as potentially compromised until reviewed. `SOC` [S7] [S10] [S24]

Short term (1–7 days)

- After upgrading, confirm /api/v1/auto_login returns 403 from a host you control, and confirm LANGFLOW_AUTO_LOGIN is not explicitly set to true, because an explicit override reopens the path. `IT OPS` [S10] [S14]
- Revoke sessions and review API keys. Disabling auto-login does not revoke existing sessions or API keys. `IT OPS` [S14]
- Rotate model, tool and cloud API keys stored in Langflow global variables or injected into its environment if untrusted people could have had access. Search repositories for exported flow files, since upgrading does not clean earlier exports. `IT OPS` [S10] [S11]
- Review exposed hosts for unexpected custom components, accounts, API keys, malicious MCP server configurations, cron entries, SSH keys, unfamiliar Python files and unexplained outbound connections. `SOC` [S10] [S21] [S24]
- Deploy the hunting queries in this report after tuning, and alert on shell processes and outbound connections from Langflow hosts. `SOC` [S24]
- Check per-project MCP server settings and change any set to no authentication, which the documentation describes as a public endpoint, to API key or OAuth. `IT OPS` [S26]

Long term

- Add AI agent and workflow platforms to asset inventory, patch management and external attack surface monitoring, including unsanctioned deployments. `LEADERSHIP` [S24]
- Set a policy that AI orchestration tools are not exposed directly to the internet and require authenticated access, segmentation and named owners. `LEADERSHIP` [S24] [S25]
- Move secrets out of Langflow environment variables and into a managed secret store with narrowly scoped, short-lived keys where the deployment allows it, so a server compromise exposes less. This is an analyst recommendation derived from the credential-theft reporting. `IT OPS` [S21] [S22]
- Watch Langflow releases and IBM bulletins directly, since recent fixes shipped days to weeks before the matching bulletins and CVE records were published. `SOC` [S2] [S11] [S19] [S20]

Workarounds & compensating controls

- If an upgrade must wait, bind Langflow to 127.0.0.1 or restrict it by firewall or VPN to named users. HOL notes that loopback-bound servers are not reachable by the no-login network bugs. IBM lists no workaround, so treat this as temporary risk reduction only. `IT OPS` [S2] [S12]
- Set LANGFLOW_AUTO_LOGIN=false, LANGFLOW_ENABLE_SIGNUP=false and leave LANGFLOW_SKIP_AUTH_AUTO_LOGIN unset, and limit accounts to trusted users. These steps reduce exposure, but sources disagree on whether they block the unauthenticated flaws. `IT OPS` [S10] [S11] [S12] [S14]
- Consider LANGFLOW_MCP_SSE_ENABLED=false where SSE is not needed; the documentation says it makes the SSE transport and message endpoint return 404. Streamable HTTP stays available, and no source confirms this mitigates the CVEs. `IT OPS` [S26]
- Apply LANGFLOW_MCP_SERVER_INTERPRETER_HARDENING=true and LANGFLOW_CUSTOM_COMPONENT_ADMIN_ONLY=true as reported by HOL from IBM's 1.12.5 bulletin. These were recommended for MCP stdio servers, not for these four CVEs. `IT OPS` [S11]
- Consider a temporary block of 185.177.72.0/24 as F5 suggests, as a supplementary measure against related scanning only. `SOC` [S22]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Critical Langflow Flaws Could Let Unauthenticated Attackers Run Code on Servers
Published 2026-11-02 · `B2` Usually reliable, probably true
Briefing source; consolidates the IBM, Metasploit and KEV data.

[S2] IBM: Security Bulletin: Langflow OSS is affected by multiple vulnerabilities (7294467)
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory, revised 2026-10-29. Lists seven CVEs including three in Hono.

[S3] CVE Program: CVE-2026-93680 record
Published 2026-10-29 · `A1` Completely reliable, confirmed by other sources
Primary record with CISA ADP SSVC: exploitation none, automatable yes, technical impact total.

[S4] CVE Program: CVE-2026-110186 record
Published 2026-10-29 · `A1` Completely reliable, confirmed by other sources
Primary record with CISA ADP SSVC: exploitation none, automatable yes, technical impact total.

[S5] CVE Program: CVE-2026-110193 record
Published 2026-10-29 · **A1** Completely reliable, confirmed by other sources
Primary record with CISA ADP SSVC: exploitation none, automatable no, technical impact total.

[S6] CVE Program: CVE-2026-110192 record
Published 2026-10-29 · **A1** Completely reliable, confirmed by other sources
Primary record.

[S7] Rapid7 Metasploit (GitHub): Pull Request #21942: Auxiliary module for Langflow Authentication Bypass CVE-2026-93680
Published 2026-09-22 · **A2** Completely reliable, probably true
Module development record; merged 2026-10-08. Read for behavior only.

[S8] Rapid7 Metasploit (GitHub): langflow_auth_bypass_cve_2026_93680 module page
Published 2026-10-08 · **A2** Completely reliable, probably true
Reviewed only for a description of behavior; no code was run or reproduced. The date shown is the merge date.

[S9] Rapid7: Metasploit Wrap Up: Langflow, MongoDB, and More
Published 2026-10-23 · **A2** Completely reliable, probably true
Announces six Langflow modules; gives the narrower affected range.

[S10] Ostorlab: Langflow Auto-Login Superuser Bypass, RCE via MCP (CVE-2026-93680)
Published 2026-10-30 · **C3** Fairly reliable, possibly true
Only source describing the auto-login to MCP chain and code paths. Not confirmed by IBM; conflicts with HOL on endpoint and on the effect of disabling auto-login.

[S11] HOL Guard: Langflow CVE-2026-93680: 33 CVEs, how to fix (upgrade to 1.13.0)
Published 2026-10-29 · **C2** Fairly reliable, probably true
Useful consolidation citing primary sources; modified 2026-11-02. Smaller vendor.

[S12] HOL Guard: Langflow OSS 33-CVE disclosure: no-login auth bypass and code execution through 1.12.8
Published 2026-10-29 · **C3** Fairly reliable, possibly true
Reports no hands-on testing of 1.12.8 or 1.13.0, so its statement on auto-login-off risk is not validated.

[S13] Langflow (GitHub): Release v1.13.0
Published 2026-10-22 · **A1** Completely reliable, confirmed by other sources
Primary release notes. The page shows day and time without a year; the year comes from S1, S10 and S11.

[S14] Langflow Documentation: API keys and authentication
Published · **A1** Completely reliable, confirmed by other sources
Primary guidance on auto-login upgrade and recovery; describes current defaults.

[S15] Langflow Documentation: Install Langflow
Published · **A1** Completely reliable, confirmed by other sources
Primary upgrade guidance and warning against reinstalling.

[S16] Langflow (GitHub): auth.py settings at v1.12.8
Published · **A1** Completely reliable, confirmed by other sources
Primary source confirming the AUTO_LOGIN default of true in 1.12.8.

[S17] CISA: Known Exploited Vulnerabilities Catalog (version 2026.10.30)
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Six Langflow entries read directly. The four CVEs were absent from the newest entries, 2026-10-30 back to 2026-09-16; the older portions read held only the other Langflow CVEs. The full catalog was not read.

[S18] FIRST: EPSS API results for the four CVEs
Published 2026-11-02 · **A2** Completely reliable, probably true
Model output, not evidence of exploitation; scores may lag new CVEs.

[S19] IBM: Security Bulletin: Langflow OSS is affected by multiple vulnerabilities (7293015)
Published 2026-10-19 · **A1** Completely reliable, confirmed by other sources
Lists 16 CVEs fixed in 1.12.4.

[S20] IBM: Security Bulletin: Langflow OSS is affected by multiple vulnerabilities (7293016)
Published 2026-10-19 · **A1** Completely reliable, confirmed by other sources
Lists 14 CVEs associated with 1.12.5, three of them fixed in earlier versions.

[S21] The Hacker News: Langflow's Critical Authenticated RCE Flaw Targeted in 1,423 Honeypot Exploit Attempts
Published 2026-10-15 · **B2** Usually reliable, probably true
Reports Previdian honeypot data on a different CVE. The date is taken from the article's references to activity on 2026-10-15 and is approximate.

[S22] F5 Labs: Attackers Target AI Development Platform Langflow
Published 2026-10-06 · **B2** Usually reliable, probably true
Honeynet data on CVE-2026-0768; does not establish successful compromise.

[S23] The Hacker News: CISA KEV coverage of Langflow CVE-2026-9198 (title approximated from the URL)
Published · **B2** Usually reliable, probably true
States a KEV date of 2026-08-05; the catalog says 2026-08-04, and this report uses the catalog.

[S24] Cloud Security Alliance: Langflow Path Traversal: Unauthenticated RCE Actively Exploited
Published 2026-06-12 · **B2** Usually reliable, probably true
Secondary source for the CVE-2026-33017 timing, attributed to Sysdig, and for host checks on a different CVE.

[S25] VentureBeat: 7,000 Langflow servers are under attack. LangGraph and LangChain have the same holes
Published 2026-06-19 · **B3** Usually reliable, possibly true
Censys-attributed figure of about 7,000 exposed instances. More than four months old and not a current count.

[S26] Langflow Documentation: Use Langflow as an MCP server
Published · **A1** Completely reliable, confirmed by other sources
Primary documentation on MCP authentication options, transport paths and the SSE disable setting.

[S27] PyPI: langflow package metadata
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Shows 1.13.0 as the latest version when checked. The date is the retrieval date.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2025-05-05	CVE-2025-3248 is added to KEV; the catalog now flags it with known ransomware use.	[S17]
2026-09-22	Metasploit pull request for CVE-2026-93680 is opened publicly; the module lists this as its disclosure date.	[S7] [S8]
2026-10-08	The Metasploit module is merged.	[S7]
2026-10-15	Honeypot reporting shows active attempts against another Langflow flaw, CVE-2026-105740, including auto-login probes.	[S21]
2026-10-19	IBM publishes bulletins for fixes in 1.12.4 and 1.12.5.	[S19] [S20]
2026-10-22	Langflow 1.13.0 is released with fixes and auto-login off by default. 1.12.8, released the same day, remains affected.	[S1] [S13]
2026-10-23	Rapid7's weekly wrap-up announces the module alongside five other Langflow modules.	[S9]

Date	Event	Source
2026-10-28	IBM publishes bulletin 7294467.	[S2]
2026-10-29	IBM revises the bulletin and publishes the CVE records.	[S2] [S3] [S11]
2026-10-30	KEV catalog version 2026.10.30 is released without these CVEs. Ostorlab publishes its technical analysis.	[S10] [S17]
2026-11-02	The Hacker News reports on the flaws. EPSS for CVE-2026-93680 is about 2.2%, and PyPI shows 1.13.0 as the latest version.	[S1] [S18] [S27]

Relevance to Indianapolis, Indiana & managed clients

We found no reporting that names Indianapolis or Indiana organizations as affected or targeted. The practical concern is unmanaged adoption. Tools like Langflow can be installed by a developer or data team outside normal IT, so the greatest risk for local manufacturers, hospitals and clinics, universities and school districts, government agencies and small businesses is an unknown instance on a cloud virtual machine or container that holds API keys. Healthcare and government teams should also consider what data connected flows can reach, because a stolen key or superuser session may open access to records and to services beyond the Langflow server, which can trigger breach-assessment duties. Managed IT clients should get an external scan for port 7860 and common proxy paths, a check of cloud and container inventories, a question to business units about AI pilots, and a coordinated upgrade window that allows for the auto-login sign-in change. Service providers should also check any Langflow instances they run for internal automation, since credentials held there could reach several client environments.

Intelligence gaps

- No public, authoritative root-cause analysis exists. IBM names no endpoints, and the mapping of the MCP enumeration wording to CVE-2026-110186 is an inference.
- It is unresolved whether LANGFLOW_AUTO_LOGIN=false blocks CVE-2026-93680 or CVE-2026-110186 on affected versions. Testing against 1.12.8 with auto-login off would settle it; HOL reports no hands-on testing.
- It is unclear why the Metasploit range stops at 1.11.4 and starts at 1.5.0, while IBM's covers 1.0.0 through 1.12.8. The module was tested only on 1.8.4, and no source explains the difference.
- No current count of internet-exposed Langflow instances, or of those on affected versions, was found. The most recent figure is about 7,000, from June 2026 [S25].
- No attacker infrastructure, malware or named actor is tied to these four CVEs. Watch Previdian, GreyNoise, VulnCheck, F5 Labs and Sysdig for first reports of exploitation, and watch KEV for additions.
- NVD analysis could not be retrieved during research, so CVSS scores here are IBM's as the CNA.

Other notes

- Date and disclosure order: the public Metasploit work began on 2026-09-22, a month before the fix shipped and about five weeks before the CVE record was published on 2026-10-29. Public detail on unauthenticated MCP access was therefore available well ahead of the advisory, so the look-back window should start no later than that date.

- Excerpt check: the briefing's claims about affected versions, the fix, the Metasploit module's limits and the six KEV-listed Langflow flaws were all confirmed against primary or directly read sources. The KEV entries are CVE-2025-3248 (2025-05-05), CVE-2026-33017 (2026-03-25), CVE-2025-34291 (2026-05-21), CVE-2026-55255 (2026-07-07), CVE-2026-0770 (2026-07-21) and CVE-2026-9198 (2026-08-04) [S17].
- Bulletin scope: S2 also lists Hono flaws CVE-2026-84363, CVE-2026-84364 and CVE-2026-84365. Ostorlab says 1.13.0 updates Hono to 4.13.5 [S2] [S10].
- Wider batch: HOL and The Hacker News count 33 Langflow CVE records published on 2026-10-29, including CVE-2026-104339 (9.8, unauthenticated, fixed in 1.12.4) and three 9.9 flaws fixed in 1.12.5 [S1] [S11]. Upgrading to 1.13.0 covers those too. The counts do not align exactly: bulletin 7293016 lists 14 CVEs, while HOL counts 13 cleared by 1.12.5 [S11] [S20].
- Dispute on endpoints: HOL reports /api/v1/mcp/sse and Ostorlab reports /api/v1/agentic/mcp [S10] [S11]. They may be separate routes in one attack surface, but no source reconciles them. The module page reviewed did not itself confirm the literal SSE path.
- EPSS caution: the scores are low for CVSS 9.8 flaws, and the CVEs are only days old. Do not use EPSS to defer patching given the public module and Langflow's exploitation history [S17] [S18].
- Related CVE-2026-9198 telemetry: KEVIntel recorded 650 attempts from 244 addresses in 41 countries starting 2026-07-06, per The Hacker News. This shows the level of attacker interest in Langflow generally [S23].

CTI-20261102-04 v1.0 · Generated 2026-11-02 12:40 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.